DOCUMENTACIÓN TÉCNICA

Dosis Compartida

APIs de las interfaces de entrada de información

Servidor: Node.js + Express · Base de datos: PostgreSQL
Cliente: aplicación iOS (SwiftUI)
Versión 1.0 · Noviembre de 2026

Este documento describe las APIs que reciben la información capturada en las interfaces (pantallas) de la app iOS. Para cada pantalla se indica qué datos captura el usuario, qué API los recibe, qué valida el servidor y en qué tabla de PostgreSQL se guardan.

- Servidor: Node.js + Express. Base de datos: PostgreSQL. Código en la carpeta `backend/`.
- URL base: `http://<servidor>:3000` (en desarrollo, `http://localhost:3000`).
- Formato: JSON, salvo la subida de audio. Todos los textos van en UTF-8.

---

1. Interfaces de entrada y la API que usa cada una

#	Pantalla de la app	Qué captura el usuario	API que recibe la información	Tabla donde se guarda
1	Inicio de sesión	Correo y contraseña	`POST /api/auth/login`	`refresh_tokens` (sesión)
2	Hoy > Registrar dosis, paso 1 (verificar)	Foto de la etiqueta de la caja o blíster	*Ninguna: la foto se lee en el teléfono (Vision) y no se sube.* Solo viaja el resultado, en el punto 3	
3	Hoy > Registrar dosis, paso 2 (confirmar)	La dosis a registrar y el resultado de la verificación	`POST /api/dosis/:id/administrar`	`administraciones` y `medicamentos` (descuenta existencias)
4	Medicinas > Registrar reposición	Cantidad de pastillas recibidas	`POST /api/inventario/:id/reposicion`	`medicamentos`
5	Medicinas > Enviar a farmacia	Pulsar el botón en un medicamento con existencias bajas	`POST /api/inventario/:id/enviar-farmacia`	`pedidos_farmacia` y `medicamentos`
6	Notas > Grabar nota	Audio hablado (hasta 3 minutos)	`POST /api/notas`	`notas_voz` y archivo de audio
7	Administración (aún sin pantalla en la app)	Datos de un nuevo cuidador	`POST /api/admin/cuidadores`	`cuidadores`
8	Administración (aún sin pantalla en la app)	Datos de un nuevo medicamento y sus horarios	`POST /api/admin/medicamentos`	`medicamentos` y `horarios`

#	Pantalla de la app	Qué captura el usuario	API que recibe la información	Tabla donde se guarda
9	Ajustes	Modo demostración, URL del servidor, recordatorios	*Ninguna: se guardan solo en el teléfono.*	

Las pantallas de consulta (Hoy, Historial, Medicinas, Notas) leen con las APIs de la sección 4.

---

2. Convenciones

Autenticación

Todas las rutas, salvo `login`, `refresh` y `health`, exigen la cabecera:

```
Authorization: Bearer <accessToken>
```

El `accessToken` (JWT) dura 15 minutos. Cuando vence, la app lo cambia por uno nuevo con `POST /api/auth/refresh`; el `refreshToken` dura 30 días y se invalida al usarse (rotación). Las rutas `/api/admin/*` además exigen que el cuidador tenga rol `administrador`.

Errores

Todos los errores tienen el mismo formato:

```
{ "error": "Mensaje para mostrar al usuario." }
```

Código	Significado
400	Datos inválidos o incompletos
401	Falta iniciar sesión, la sesión expiró o las credenciales son incorrectas
403	El cuidador no tiene permiso (no es administrador)
404	El recurso no existe
409	Conflicto (por ejemplo, la dosis ya se registró hoy)
413	El contenido enviado es demasiado grande
415	Formato de audio no permitido

Código	Significado
429	Demasiados intentos de inicio de sesión
500	Error interno del servidor

Fechas

En formato ISO 8601 en UTC y sin milisegundos, por ejemplo `2026-11-11T13:04:00Z`. Las horas programadas de las dosis son texto `HH:MM` en la zona horaria del servidor.

---

3. APIs de entrada de información

3.1 Iniciar sesión (pantalla "Inicio de sesión")

`POST /api/auth/login`

Campo	Tipo	Obligatorio	Validación
`correo`	texto	Sí	No vacío; no distingue mayúsculas
`password`	texto	Sí	No vacío

Petición:

```
{ "correo": "ana@correo.com", "password": "demo1234" }
```

Respuesta `200`:

```
{
  "accessToken": "eyJhbGciOiJIUzI1NiIs...",
  "refreshToken": "9f2c4e...",
  "cuidador": { "id": "37e97213-71a1-4d77-af60-1f3bf986334a", "nombre": "Ana Pérez",
                "correo": "ana@correo.com", "rol": "administrador" }
}
```

Errores: `400` "Escribe tu correo y contraseña." · `401` "Correo o contraseña incorrectos." · `429` "Demasiados intentos. Espera unos minutos." (a partir de 5 fallos por IP y correo en 15 minutos).

Rutas relacionadas: - `POST /api/auth/refresh` con `{ "refreshToken": "..." }`: devuelve la misma respuesta con tokens nuevos (`401` si el token ya se usó o venció). - `POST /api/auth/logout` (con Bearer): cierra todas las sesiones del cuidador. Responde `{ "ok": true }`.

3.2 Registrar una dosis (pantalla "Hoy", pasos 1 y 2)

En el paso 1 el cuidador fotografía la etiqueta de la caja o blíster. La app lee el texto en el propio teléfono y lo compara con la dosis programada; el resultado puede ser `coincide`, `no_coincide` u `omitida` (si el cuidador omitió la verificación o no se pudo leer). La foto no se envía al servidor.

En el paso 2, al confirmar:

`POST /api/dosis/:id/administrar`

Parámetro	Dónde	Tipo	Obligatorio	Validación
`id`	ruta	UUID	Sí	Es el `id` de la dosis que devuelve `GET /api/dosis`
`verificacion`	cuerpo JSON	texto	No (por defecto `omitida`)	Solo `coincide`, `no_coincide` u `omitida`

Petición:

```
{ "verificacion": "coincide" }
```

Respuesta `201`: la dosis ya registrada y el inventario actualizado (se descontó la cantidad por dosis):

```
{
  "dosis": { "id": "b99d800e-6b87-4390-bfb3-825116deadca", "hora": "13:00",
             "medicamento": "Metformina 850 mg", "indicacion": "1 tableta",
             "estado": "administrada", "registradaPor": "Ana Pérez", "horaRegistro": "18:28" },
  "inventario": { "id": "1165902f-7ada-489b-939b-adebc92e87f8", "nombre": "Metformina 850 mg",
                  "cantidad": 29, "umbral": 30, "bajo": true, "enviadoAFarmacia": false }
}
```

Errores: `400` "Identificador de dosis inválido." / "Verificación inválida." · `404` "La dosis no existe." · `409` "Esta dosis ya fue registrada hoy."

Garantías: el registro y el descuento del inventario ocurren en una sola transacción. Si dos cuidadores registran la misma dosis a la vez, solo uno la registra (el otro recibe `409`) y el inventario baja una sola vez.

3.3 Registrar una reposición de inventario (pantalla "Medicinas")

`POST /api/inventario/:id/reposicion`

Parámetro	Dónde	Tipo	Obligatorio	Validación
`id`	ruta	UUID	Sí	Id del medicamento (de `GET /api/inventario`)
`cantidad`	cuerpo JSON	entero	Sí	De 1 a 100000

Petición: `{ "cantidad": 10 }`

Respuesta `200`: el medicamento actualizado. Si con la reposición ya no está bajo, `enviadoAFarmacia` vuelve a `false`.

```
{ "id": "1165902f-...", "nombre": "Metformina 850 mg", "cantidad": 39, "umbral": 30,
  "bajo": false, "enviadoAFarmacia": false }
```

Errores: `400` "La cantidad debe ser un entero mayor que 0." · `404` "El medicamento no existe."

3.4 Enviar pedido a la farmacia (pantalla "Medicinas")

`POST /api/inventario/:id/enviar-farmacia` (sin cuerpo)

Crea un pedido en `pedidos_farmacia` y marca el medicamento como enviado. Respuesta `201`: el medicamento con `"enviadoAFarmacia": true`.

Errores: `404` "El medicamento no existe." · `409` "Este medicamento no está bajo en inventario." · `409` "Ya se envió el pedido a la farmacia."

> Hoy el pedido queda registrado, pero el servidor todavía no envía el correo a la farmacia.

3.5 Subir una nota de voz (pantalla "Notas")

`POST /api/notas`

A diferencia de las demás, esta ruta no recibe JSON: el cuerpo de la petición es el archivo de audio.

Elemento	Dónde	Obligatorio	Validación
Audio	cuerpo	Sí	No vacío; máximo 10 MB
`Content-Type`	cabecera	Sí	`audio/mp4`, `audio/x-m4a`, `audio/m4a`, `audio/mpeg`, `audio/wav` o `audio/x-wav`
`X-Duracion-Seg`	cabecera	Sí	Entero de 1 a 3600

La app graba en `.m4a` (AAC, mono) y envía `Content-Type: audio/mp4`.

Respuesta `201`:

```
{ "id": "de75cf0d-6c92-4379-a6c8-b3978e403162", "fecha": "2026-11-12T00:28:42Z",
  "autor": "Ana Pérez", "duracionSegundos": 75 }
```

Errores: `400` "El audio está vacío." / "Falta la cabecera X-Duracion-Seg (1 a 3600)." · `413` "El contenido es demasiado grande." · `415` "Formato de audio no permitido (usa m4a, mp3 o wav)."

3.6 Dar de alta un cuidador (solo administrador; aún sin pantalla en la app)

`POST /api/admin/cuidadores`

Campo	Tipo	Obligatorio	Validación
`nombre`	texto	Sí	Máximo 100 caracteres
`correo`	texto	Sí	Correo válido, máximo 120; único sin importar mayúsculas
`password`	texto	Sí	Mínimo 8 caracteres (se guarda cifrada con bcrypt)
`rol`	texto	No	`administrador` o `cuidador` (por defecto `cuidador`)

Petición:

```
{ "nombre": "Marta Ruiz", "correo": "marta@correo.com", "password": "password123", "rol": "cuidador" }
```

Respuesta `201` : `{ "id": "...", "nombre": "Marta Ruiz", "correo": "marta@correo.com", "rol": "cuidador", "activo": true }`

Errores: `400` (nombre, correo o contraseña inválidos) · `403` "Solo el administrador puede hacer esto." · `409` "Ya existe un cuidador con ese correo."

3.7 Dar de alta un medicamento (solo administrador; aún sin pantalla en la app)

`POST /api/admin/medicamentos`

Campo	Tipo	Obligatorio	Validación
`nombre`	texto	Sí	Máximo 100 caracteres (por ejemplo "Aspirina 100 mg")
`indicacion`	texto	Sí	Máximo 100 caracteres (por ejemplo "1 tableta")
`unidadesPorDosis`	entero	No	De 1 a 100 (por defecto 1); es lo que se descuenta del inventario en cada dosis
`cantidad`	entero	Sí	De 0 a 100000 (existencias iniciales)
`umbral`	entero	Sí	De 0 a 100000; por debajo de este número se alerta
`horarios`	lista de texto	Sí	Al menos uno, formato `HH:MM` de 24 horas, sin repetir

Petición:

```
{ "nombre": "Aspirina 100 mg", "indicacion": "1 tableta", "unidadesPorDosis": 1,
  "cantidad": 60, "umbral": 20, "horarios": ["08:30", "20:30"] }
```

Respuesta `201` : el medicamento creado con sus `horarios` . A partir de ese momento aparece en `GET /api/dosis` .

Errores: `400` (campos inválidos u horarios mal formados) · `403` "Solo el administrador puede hacer esto."

Relacionada: `DELETE /api/admin/medicamentos/:id` da de baja el medicamento (baja lógica: se conserva el historial). Responde `{ "ok": true }` .

---

4. APIs de consulta (alimentan las pantallas)

Método y ruta	Pantalla	Devuelve
`GET /api/paciente`	Hoy	`{ nombre, edad, padecimientos, alergias[] }`
`GET /api/dosis`	Hoy	Lista de dosis de hoy: `{ id, hora, medicamento, indicacion, estado, registradaPor, horaRegistro }` ; `estado` es `pendiente` o `administrada`
`GET /api/historial?dias=30&cuidador=<id>`	Historial	Dosis administradas por todos los cuidadores: `{ id, fecha, medicamento, indicacion, horaProgramada, cuidador, verificacion }` . `dias` : de 1 a 365 (por defecto 30); `cuidador` : filtro opcional por UUID
`GET /api/inventario`	Medicinas	`{ id, nombre, cantidad, umbral, bajo, enviadoAFarmacia }`
`GET /api/notas`	Notas	`{ id, fecha, autor, duracionSegundos }`
`GET /api/notas/:id/audio`	Notas	El archivo de audio de la nota
`GET /api/admin/cuidadores`	(administración)	Lista de cuidadores (solo administrador)
`GET /api/health`	(comprobación)	`{ "ok": true }`

---

5. Cómo probar las APIs sin la app

Con el servidor en marcha (ver `backend/README.md`):

```
# 1. Iniciar sesión y guardar el token
TOKEN=$(curl -s -H "Content-Type: application/json" \
  -d '{"correo":"ana@correo.com","password":"demo1234"}' \
  http://localhost:3000/api/auth/login | sed 's/.*"accessToken":"\([^"]*\)".*/\1/')

# 2. Ver las dosis de hoy (copia un "id")
curl -H "Authorization: Bearer $TOKEN" http://localhost:3000/api/dosis

# 3. Registrar esa dosis con la etiqueta verificada
curl -X POST -H "Authorization: Bearer $TOKEN" -H "Content-Type: application/json" \
  -d '{"verificacion":"coincide"}' http://localhost:3000/api/dosis/<id>/administrar

# 4. Ver el historial compartido
curl -H "Authorization: Bearer $TOKEN" http://localhost:3000/api/historial
```

6. Seguridad

- Contraseñas cifradas con bcrypt; el servidor nunca las devuelve.
- Tokens JWT de corta duración y tokens de renovación de un solo uso, guardados como hash.
- Máximo 5 intentos fallidos de inicio de sesión por IP y correo cada 15 minutos.
- Consultas SQL parametrizadas (protección contra inyección SQL). Se probó con un intento real.
- Permisos de administrador comprobados en el servidor.
- En la app, el token de renovación se guarda en el Keychain de iOS.
- Falta para producción: HTTPS (hoy en desarrollo se usa `http://`), copias de seguridad de la base de datos y una revisión de privacidad de los datos de salud.